



PROFESOR:

Alexis Moisés Montaño Araujo

MATERIA:

DBA

ALUMNO

José Mario Rivera Félix

GRUPO:

4 – 1

1. ¿Cuál era la principal superficie de ataque?

La principal superficie de ataque estaba formada por las interfaces de escucha, el puerto de PostgreSQL, las reglas de acceso de pg_hba.conf, las cuentas de usuario, los privilegios asignados y las conexiones al servidor. En el diagnóstico se observó que listen_addresses tenía el valor '*', lo que permitía a PostgreSQL escuchar en todas las interfaces disponibles, sujeto a las reglas de red y autenticación. Esto podía aumentar la exposición del servidor si no existían restricciones adecuadas en el firewall.

2. ¿Qué configuración representaba el mayor riesgo?

La configuración que más destacaba era listen_addresses', porque podía permitir que PostgreSQL aceptara conexiones a través de interfaces de red que no eran necesarias. Además, el parámetro ssl = 'off' indicaba que TLS no estaba habilitado en la configuración observada, lo que suponía un riesgo para la confidencialidad de las conexiones de red. Ambos aspectos debían evaluarse y corregirse según las necesidades reales del servidor.

3. ¿Qué cambio produjo la mayor reducción de exposición?

Si el servidor solo se utiliza localmente, cambiar listen_addresses de * a localhost produciría una reducción importante de la exposición al impedir que PostgreSQL escuche en interfaces de red externas. Si necesita conexiones remotas, la alternativa sería limitar las interfaces, las redes permitidas y las reglas del firewall. El cambio debe probarse para asegurar que las aplicaciones autorizadas sigan funcionando.

4. ¿Qué diferencia existe entre firewall y pg_hba.conf?

El firewall controla el tráfico de red que puede llegar al equipo y al puerto de PostgreSQL. En cambio, pg_hba.conf define las reglas mediante las cuales PostgreSQL acepta o rechaza intentos de conexión según la base de datos, el usuario, el origen y el método de autenticación. Ambos controles se complementan: el firewall reduce las conexiones que pueden llegar al servidor y pg_hba.conf limita cuáles pueden autenticarse en PostgreSQL.

5. ¿Qué diferencia existe entre autenticación y autorización?

La autenticación verifica la identidad de quien intenta conectarse al servidor, por ejemplo, mediante una contraseña. La autorización determina qué acciones puede realizar esa identidad una vez autenticada, como consultar tablas, insertar registros o administrar bases de datos. Una cuenta puede autenticarse correctamente y, aun así, no tener permiso para ejecutar una operación determinada.

6. ¿Por qué una cuenta de aplicación no debe ser SUPERUSER?

Una cuenta de aplicación no debe tener el atributo SUPERUSER porque dispone de privilegios administrativos extremadamente amplios. Si sus credenciales fueran robadas o la aplicación fuera comprometida, un atacante podría aprovechar esos privilegios para acceder a información, modificar configuraciones o realizar acciones administrativas. Por eso, las aplicaciones deben utilizar cuentas con permisos limitados a las operaciones que realmente necesitan.

7. ¿Por qué cambiar el puerto de PostgreSQL no constituye hardening suficiente?

Cambiar el puerto predeterminado 5432 puede reducir algunos intentos automatizados y superficiales, pero no impide que un atacante identifique el nuevo puerto mediante técnicas de reconocimiento. La seguridad debe basarse en controles efectivos, como el firewall, las restricciones de acceso, la autenticación robusta, los privilegios mínimos y el cifrado de las conexiones. Ocultar el puerto no sustituye estas medidas.

8. ¿Por qué listen_addresses='*' puede ser innecesario?

Porque hace que PostgreSQL escuche en todas las interfaces disponibles, incluso en aquellas que no necesita utilizar. Si el servidor solo recibe conexiones locales, puede configurarse con listen_addresses = 'localhost'. Si requiere conexiones remotas, deben habilitarse únicamente las interfaces necesarias y restringirse los orígenes permitidos. Esto reduce la exposición sin afectar los servicios que realmente necesitan conectarse.

9. ¿Qué papel tiene el sistema operativo en la seguridad de PostgreSQL?

El sistema operativo protege los archivos, directorios, certificados, claves privadas, copias de seguridad y procesos del servidor. Una configuración correcta de PostgreSQL no es suficiente si usuarios no autorizados pueden modificar postgresql.conf, acceder al directorio de datos o copiar archivos sensibles. Por ello, deben limitarse los permisos de Windows, protegerse las credenciales y mantenerse actualizados tanto el sistema operativo como PostgreSQL.

10. ¿Qué controles deberían revisarse periódicamente?

Deben revisarse las interfaces de escucha, el puerto, las reglas del firewall, el archivo pg_hba.conf, los métodos de autenticación, los roles y sus privilegios, las cuentas administrativas y de aplicación, las extensiones instaladas, los parámetros de conexión, el uso de TLS y los permisos del sistema operativo. También es importante revisar los registros de actividad, las conexiones, las actualizaciones de seguridad y las copias de respaldo, así como comprobar que estas últimas puedan restaurarse correctamente.

Reflexión

Si recibiera la responsabilidad de asegurar un servidor PostgreSQL que ya se encuentra funcionando en producción, primero identificaría su superficie de ataque y revisaría cómo se encuentra expuesto a la red. Antes de realizar modificaciones, documentaría la configuración actual, identificaría las aplicaciones y usuarios que dependen del servidor y verificaría que existan copias de seguridad recientes y funcionales.

El primer cambio que priorizaría sería restringir el acceso de red a PostgreSQL, comenzando por revisar `listen_addresses`, las reglas del firewall y `pg_hba.conf`. Si el servidor solo necesita conexiones locales, configuraría `listen_addresses = 'localhost'`. Si existen aplicaciones remotas autorizadas, conservaría las conexiones necesarias y limitaría el acceso a las direcciones IP correspondientes. Esta medida reduciría la exposición sin bloquear indiscriminadamente los servicios que dependen de la base de datos.

Elegiría este cambio primero porque el riesgo de una conexión no autorizada puede tener consecuencias graves para la confidencialidad, la integridad y la disponibilidad de la información. Sin embargo, también consideraría el impacto operativo: una modificación incorrecta de las interfaces o de las reglas de acceso podría interrumpir las aplicaciones en producción. Por eso, realizaría el cambio durante una ventana de mantenimiento, después de identificar las dependencias y preparar un procedimiento para revertirlo si fuera necesario.

Después revisaría la autenticación, asegurándome de utilizar `scram-sha-256` cuando corresponda, y comprobaría que las cuentas administrativas estén separadas de las cuentas de aplicación. También verificaría que ningún usuario de una aplicación tenga privilegios `SUPERUSER` innecesarios y que cada rol disponga únicamente de los permisos que necesita.

Posteriormente evaluaría el uso de TLS para proteger las conexiones de red y revisaría los permisos del sistema operativo, los archivos de configuración y el directorio de datos. Finalmente, establecería un calendario de actualizaciones, auditorías de privilegios, revisión de registros y pruebas de restauración de respaldos.

En conclusión, priorizaría la restricción de la exposición de red porque puede reducir de manera importante las oportunidades de acceso no autorizado. No obstante, realizaría el cambio de forma controlada, teniendo en cuenta el riesgo, el impacto, la disponibilidad y la continuidad del servicio. La seguridad en producción no consiste solamente en endurecer la configuración, sino en hacerlo sin provocar interrupciones innecesarias y manteniendo la capacidad de recuperar el servicio si surge algún problema.